

ASUS DriverHub

TOCTOU 취약점 분석

드라이버 업데이트 과정의 경쟁 상태(Race Condition)를 악용한
로컬 권한 상승 (LPE) 공격 기법 상세 분석

 Yohan Seok

 Jenblack Soft

root@victim-pc:~

```
user@victim:~$ ./poc_exploit.exe --target ASUS_Hub

[+] Target process detected: ADU.exe (PID: 4102)
[+] Monitoring C:\ProgramData\ASUS\AsusDriverHub...
[+] Race condition window identified (TOCTOU)

[*] Planting malicious 'setup.exe'...

[+] Triggering Oplock on setup.ini...
[+] Swapping binary during verification gap...

[!] Exploit Successful!

SYSTEM@victim:# whoami
nt authority\system

SYSTEM@victim:#
```

Table of Contents

01 Vulnerability Overview

- › 개요: TOCTOU 경쟁 상태와 LPE
- › 취약점 세부사항: 영향 경로 및 관찰
- › 실행 메커니즘 분석

03 Exploit Scenario

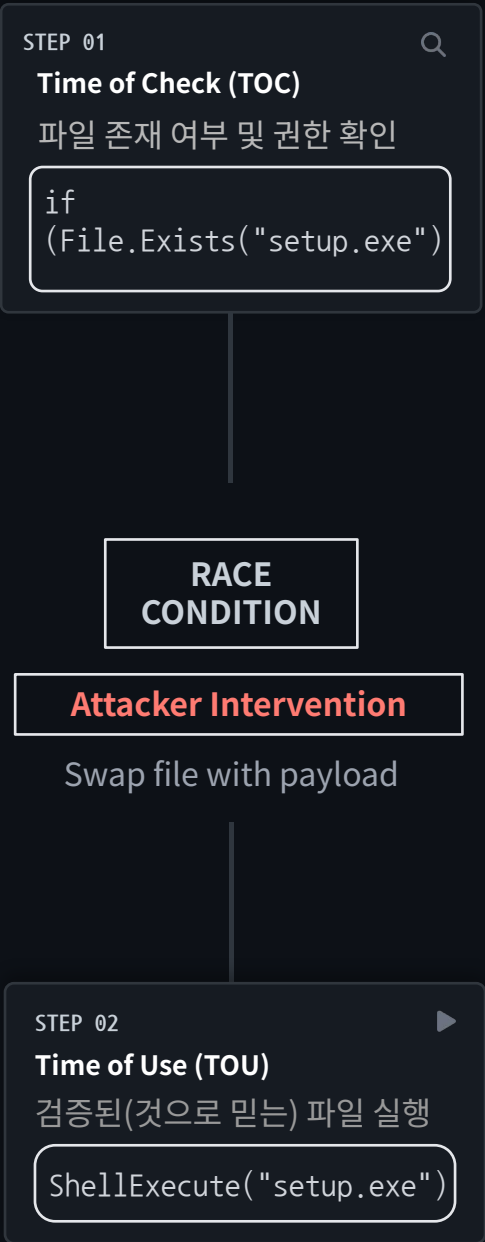
- › 공격 사전 조건 및 준비
- › 단계별 공격 흐름 (Oplock & Race)
- ▶ PoC 시연 결과 및 로그 분석

02 Code Analysis

- ‹/› 설치 상태 갱신 로직 (`selectInstall`)
- ‹/› 취약한 실행 함수 (`sub_18003E520`)
- ✱ ShellExecuteExW와 고정 경로 문제

04 Resolution

- ✓ 패치 분석: 보안 검증 추가
- 🛡️ 영향 분석 및 위험도 평가
- 💡 후기 및 결론



TOCTOU 경쟁 상태 취약점

TOCTOU (Time-of-Check to Time-of-Use):

시스템이 자원을 검사하는 시점과 실제 사용하는 시점 사이에 발생하는 시간차를 이용해, 공격자가 자원을 교체하거나 변경하는 보안 취약점입니다.

1. 검증과 실행의 괴리

ASUS DriverHub는 업데이트 과정에서 파일의 존재 여부와 무결성을 확인하지만 실행시에 다시 확인하지 않습니다.

실행 직전(ShellExecute)

2. 악성 파일 교체 (Swap)

공격자는 저권한 계정으로 미리 예측된 경로에 접근하여, 정상적인 드라이버 설치 파일을 악성 파일로 교체합니다.

악성 실행 파일(payload)

3. 로컬 권한 상승 (LPE)

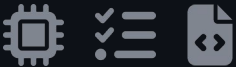
업데이트 프로세스는 관리자 또는 SYSTEM 권한으로 실행되므로, 악성 파일을 교체할 경우 높은 권한으로 실행됩니다.

상승된 권한

```
vulnerable_logic.c                                LPE Risk: High
if (IsValid(file)) {
    // <--- Attacker swaps file HERE
    Execute(file, ADMIN_PRIV);
}
```

설치 프로세스 제어 흐름

설치 상태 갱신(Installing) 및 실제 설치 함수 호출 과정 분석



CALL STACK

ToolsPageDLL.dll + 0x3e3a8 0x7ff9dc15e3a8

ToolsPageDLL.dll + 0x3ef04 0x7ff9dc15ef04

ToolsPageDLL.dll + 0x2f8d6 0x7ff9dc14f8d6

ToolsPageDLL.dll + 0x31b56 0x7ff9dc151b56

ToolsPageDLL.dll selectInstall + 0x210 0x7ff9dc1782f0

ADU.exe + 0x180ee8 0x7ff6a9780ee8

WATCH

pszZipPath: "C:\...\ZIPFileTemp"

v129 (Target): "C:\...\SupportTemp"

Status: "Installing"

// Result Flags

doInstalled: true

sub_180031920.c

```
// sub_180031920_180031920.c - 164 line
if ( v35 == i && (!v35 || !(unsigned int)sub_18022F080(v34, v33)) )

sub_1800043D0(v31 + 4, (__int64)"Installing", 0xAui64);

v38 = sub_18002EE70(v37, v36, v16);

v43 = "InstallFail";

if ( v38 == 1 )

    v43 = "Installed";

sub_1800043D0(j + 4, (__int64)v43, v44);
...
```

sub_18002EE70.c

```
// sub_18002EE70_18002EE70.c - 527 line
sub_18001A870(psz, v129);

if ( (unsigned int)sub_18003E520(a3) )

{

sub_180007890((__int64)v73, (int)"[%ls][%hs] Installed = success!!!", ...);

sub_18002D400((__int64)"true", v74, a3, (__int64)&qword_1802987E0, ...);

WideCharToMultiByte(..., (LPCWCH)(a3 + 602), ... , MultiByteStr, ...);

sub_18002D400((__int64)MultiByteStr, v76, a3, (__int64)&xmmword_180298730, ...);

}

...
```

release/v1.0

UTF-8 C++

설치 프로세스 제어 흐름

설치 상태 갱신(Installing) 및 실제 설치 함수 호출 과정 분석



CALL STACK

ToolsPageDLL.dll + 0x3e3a8 0x7ff9dc15e3a8

ToolsPageDLL.dll + 0x3ef04 0x7ff9dc15ef04

ToolsPageDLL.dll + 0x2f8d6 0x7ff9dc14f8d6

ToolsPageDLL.dll + 0x31b56 0x7ff9dc151b56

ToolsPageDLL.dll selectInstall + 0x210 0x7ff9dc1782f0

ADU.exe + 0x180ee8 0x7ff6a9780ee8

sub_180031920.c

```
// sub_18003E520_18003E520.c - 228 line
...

sub_180046340(&lpFileName, L"%s\\setup.exe", v22);

pExecInfo.lpDirectory = v22;
pExecInfo.lpFile = L"setup.exe";
pExecInfo.lpParameters = L"-s";
if ( ShellExecuteExW(&pExecInfo) )
{
v2 = 1;
...
}
```

WATCH

pszZipPath: "C:\\...\\ZIPFileTemp"

v129 (Target): "C:\\...\\SupportTemp"

Status: "Installing"

// Result Flags

doInstalled: true

release/v1.0

UTF-8 C++

TARGET SCOPE

파일 시스템 구조

```
C:\
├── ProgramData
│   └── ASUS
│       └── AsusDriverHub
│           └── SupportTemp ⚠
│               └── <driver_name> (Predicted via XML)
│                   └── setup.exe
```

Directory Permissions: Everyone / Users (Write)

Insecure ACL Configuration

🔍 취약점 세부 사항 (1)

영향받는 경로 및 주요 관찰 사항

📍 영향받는 경로 (Vulnerable Path)

ASUS DriverHub가 업데이트 임시 파일을 저장하고 실행하는 경로입니다.

TARGET
PATH

C:\ProgramData\ASUS\AsusDriverHub\SupportTemp

👁 주요 관찰 사항 (Key Observations)



저 권한 사용자 접근 가능

`SupportTemp` 디렉터리는 낮은 권한의 사용자(Low Privilege User)에 의해 디렉터리 및 파일 생성이 가능하도록 설정되어 있습니다.



폴더 이름 예측 가능성

ASUS DriverHub는 `model.xml` 파일에서 드라이버 정보를 가져오며, 이를 분석하면 생성될 드라이버 폴더 이름을 사전에 정확히 예측할 수 있습니다.



검증 절차 부재 (Missing Validation)

업데이트 과정 중 이미 존재하는 디렉터리나 파일에 대해 **소유권, 권한, 무결성을 검증하지 않으며**, 기존 디렉터리를 안전하게 삭제하거나 재생성하는 로직이 없습니다.

Prerequisites Check



CONDITION 01

Target Directory Missing

드라이버 폴더 부재 확인



CONDITION 02

Low Privilege Access

로컬 일반 사용자 접근



CONDITION 03

Write Permission

SupportTemp 쓰기 권한

ALL CONDITIONS MET: READY TO ATTACK

SCENARIO

/ attack-vector / setup

공격 시나리오: 사전 조건 (Pre-condition)

1 대상 디렉터리 부재

업데이트 시작 시점에 대상 드라이버 디렉터리가 존재하지 않아야 합니다. 공격자는 폴더 생성 시점의 경합을 이용하기 위해, 해당 경로가 비어있음을 확인하거나 유도합니다.

2 로컬 접근 권한 (Local Access)

공격자는 대상 시스템에 물리적으로 접근하거나, SSH/RDP 등을 통해 계정으로 로그인된 상태여야 합니다.

저권한(Low Privilege)

3 임시 경로 쓰기 권한

`SupportTemp` 디렉터리는 누구나 접근 가능한 경로입니다. 공격자는 이곳에 미리 예측된 이름의 폴더를 생성하고, 조작된 `setup.exe`를 배치할 수 있어야 합니다.

```
C:\> icacls SupportTemp
```

```
C:\ProgramData\ASUS\AsusDriverHub\SupportTemp
BUILTIN\Users:(OI)(CI)(F) // Full Control
NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
BUILTIN\Administrators:(I)(OI)(CI)(F)
```

Permissions Check

PoC 구현 고려사항

1. 압축 해제시 파일명 충돌 (File Name Collision)이용한 정상적인 파일 해제 우회

드라이버 ZIP 파일을 압축 해제하는 과정에서 동일한 이름의 폴더가 이미 존재해 파일명 충돌이 발생하여 높은 권한 ACL 설정된 파일이 생성되지 않습니다

2. Target 파일보다 먼저 실행되는 파일에 oplock을 적용하여 TOCTOU 트리거

setup.ini 파일이 먼저 해제되도록 한 뒤, TOCTOU 유발을 위해 oplock(Opportunistic Lock) 발생시켜 트리거부분을 만들어둡니다.

3. model.xml을 읽어 사용중인 드라이버 이름 가져와 미리 자원 선점

model.xml에 정의된 드라이버 정보를 활용하여 대상 경로를 서전에 생성함으로써, 파일명 충돌을 유도하여 정상 파일 생성 로직을 차단 할 수 있습니다.

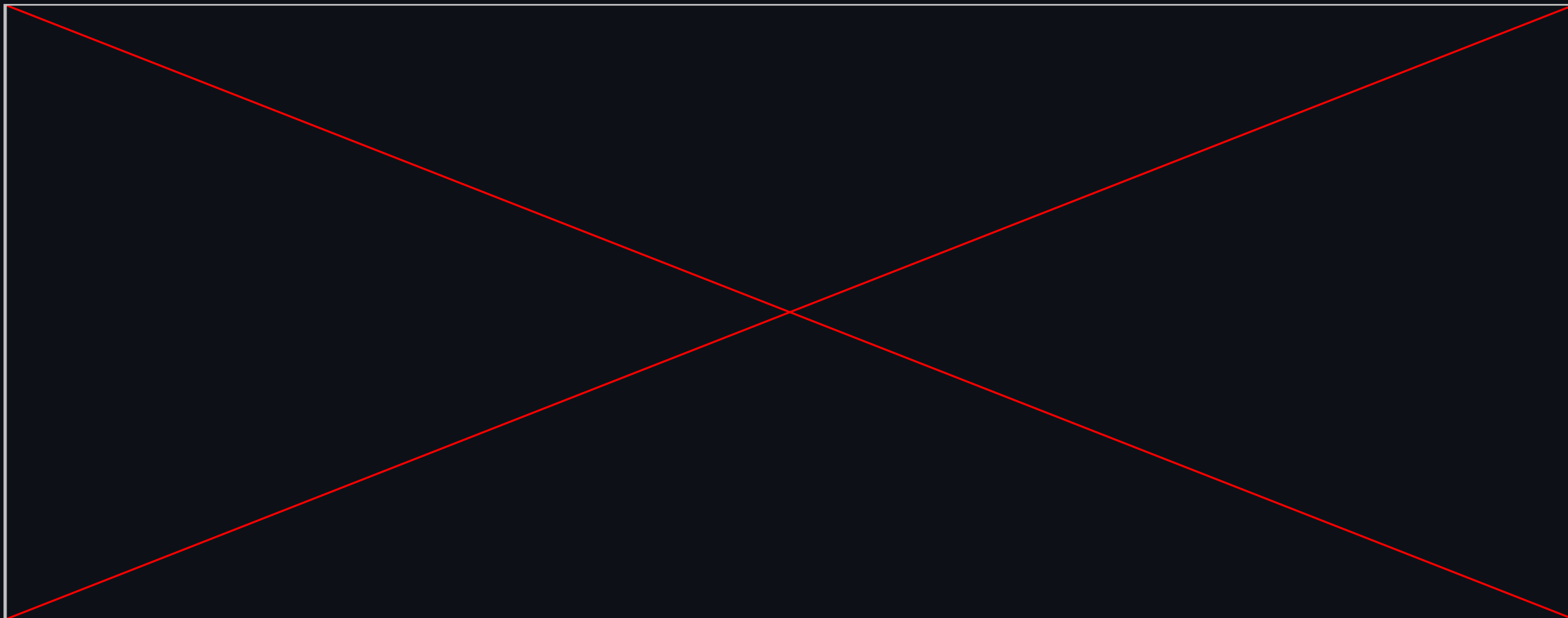
PoC

실제 공격 시연을 통해 SYSTEM 권한 탈취 및 악성 프로세스 실행 확인

Exploit Successful

Target: ASUS DriverHub v1.x

Exploit Execution



공격 시나리오: 실행 흐름도

TOCTOU 경쟁 상태를 이용한 권한 상승 공격 6단계

ASUS DriverHub 권한 상승(LPE) 취약점 공격 매커니즘

ASUS DriverHub 업데이트 과정에서 발생하는 TOCTOU(Time-of-Check Time-of-Use) 취약점의 작동 원리와 공격 단계를 설명합니다.

공격 준비 및 프로세스 트리거

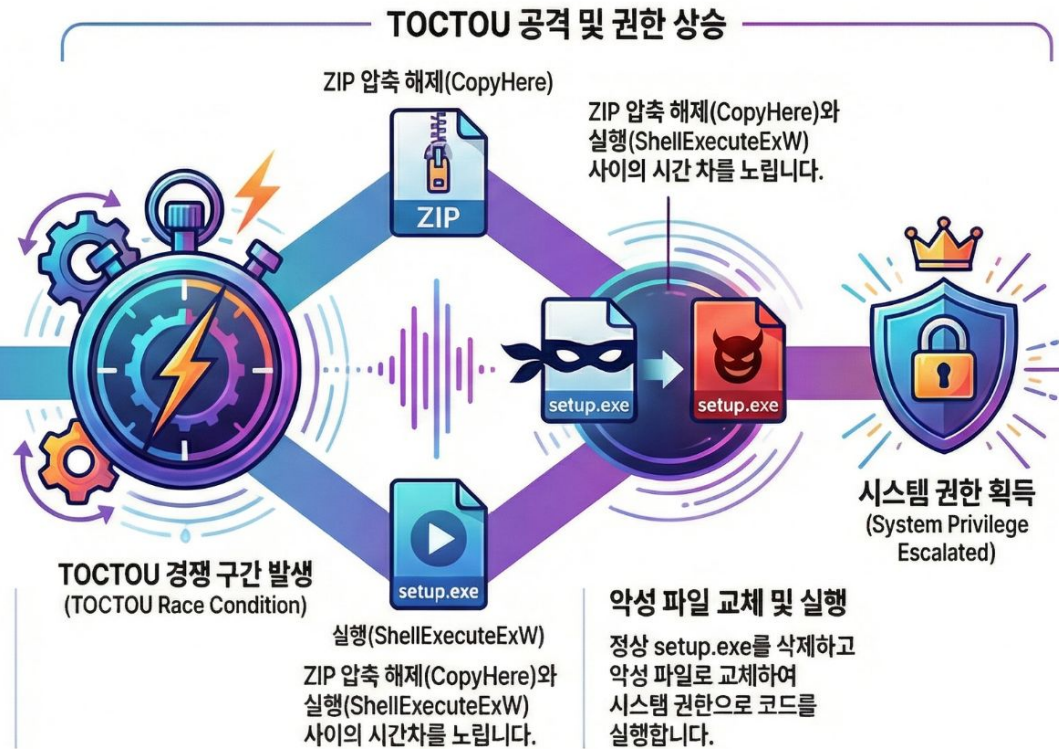


취약한 환경 사전 조성

저권한 공격자가 SupportTemp 하위 드라이버 디렉터리를 미리 생성하여 검증을 우회합니다.

업데이트 시작 및 경로 점유

사용자가 업데이트를 시작하면 시스템은 사전 생성된 디렉터리를 검증 없이 그대로 사용합니다.



SYSTEM / Admin



- ✓ Full System Control
- ✓ Arbitrary Kernel Access



TOCTOU Exploit

Low Privilege User



- ✗ Limited File Access
- ✗ No Administrative Tasks



Critical Security Alert

취약점 악용 시 별도의 사용자 상호작용 없이 즉각적인 권한 상승이 발생합니다.

Impact Analysis



Local Privilege Escalation (LPE)

가장 치명적인 영향으로, 일반 사용자 권한에서 **NT AUTHORITY\SYSTEM** 권한으로 상승합니다. 이는 공격자가 운영체제의 모든 제어권을 획득함을 의미합니다.



Arbitrary Code Execution

공격자가 준비한 임의의 실행 파일(Payload)이 DriverHub의 업데이트 프로세스를 통해 실행됩니다. 랜섬웨어 설치, 데이터 유출, 백도어 설치 등 모든 악성 행위가 가능합니다.



Persistence & Evasion

정상적인 ASUS 서명 프로세스 내부에서 실행되므로, 일부 보안 솔루션(EDR/AV)의 탐지를 우회할 가능성이 높으며, 시스템 재부팅 후에도 지속적인 접근 권한을 유지할 수 있습니다.

Affected Component: AsusDriverHub.exe

Impact Level: Critical



패치

취약점이 패치된 최신 앱 버전



ASUS.PSIRT

나, ASUS.PSIRT에게 ▾

Hi Seok

RD provide below new version link, please download and install it directly

<https://www.asuswebstorage.com/navigate/a/#/s/>

Extract password:

Best regards,

ASUS Security Advisory | ©ASUSTeK Computer Inc.

寄件者: ASUS.PSIRT

寄件日期: 2026年1月26日 上午 10:15

收件者: 서우하

보안 검증 로직 추가 (Patch)

업데이트 전 VerifyFolderSecurity 함수를 통한 ACL 권한 검증 및 무결성 확인



CALL STACK (PATCHED)

▼ 🔍

VerifyFolderSecurity.cpp

•

Install.cpp

```
bool __fastcall sub_180019EA0(char **a1) {
...

    if ( !GetNamedSecurityInfoW((LPCWSTR)a1, SE_FILE_OBJECT, 4u, 0i64, 0i64, &pAcl, 0i64, &hMem) ) {
        v10 = pAcl;
        for ( i = 0; v11 < pAcl->AceCount; ++v11 ) {
            pAce = 0i64;
            if ( GetAce(v10, v11, &pAce) ) {
                v15 = pAce;
                StringSid = 0i64;
                if ( ConvertSidToStringSidW((char *)pAce + 8, &StringSid) ) {
                    if ( (!sub_18020E738(StringSid, L"S-1-5-32-544")
                        || !sub_18020E738(StringSid, L"S-1-5-18"))
                        && (v15[1] & 0x10000000) != 0 )
                    {
                        if ( !sub_18020E738(StringSid, L"S-1-5-32-544") )
                            i = 1;
                        if ( !sub_18020E738(StringSid, L"S-1-5-18") )
                            v13 = 1;
                    }
                }
                if ( !sub_18020E738(StringSid, L"S-1-5-32-545") && (v15[1] & 6) != 0 )
                    v12 = 0; // Mark as insecure
                LocalFree(StringSid);
            }
        }
        v10 = pAcl;
    }
```

SECURITY CONTEXT

Expected SID : "S-1-5-32-544"

// Administrators

Expected SID : "S-1-5-18"

// SYSTEM

Blocked SID : "S-1-5-32-545"

// Users (Standard)

처리 현황

CVE, 명예전당 등록 ing~

Hall of Fame

<u>2026</u>	2025	2024	2023	2022	2021	2020	2019
-------------	------	------	------	------	------	------	------

March

- Gu YongZeng (@0x0dee) working with TrendAI Zero Day Initiative
- Zhihong Liu (@vincebye)

January

- Yohan Seok (@seokjohn) with JENBlack Soft

후기 및 최종 결론

📁 기존 방어 메커니즘 평가

패치 전에도 **높은 권한의 ACL 설정**과 **덮어쓰기 로직**이 존재하여, 심볼릭 링크(symmlink)나 정션(junction)파일과 같은 객체는 제거되는 구조였습니다. 그러나 실행 시점 및 기존 폴더에 대한 검증 부재가 결정적이었습니다.

⚠️ 트리거의 가변성

TOCTOU를 유발하는 트리거(예: setup.ini)가 특정 드라이버 환경마다 다를 수 있어, 다른 방식의 트리거가 필요할 수도 있습니다

- 압축해제 순서
- 트리거 파일 존재 유무

🚩 추가 취약점 가능성

본문에서 나온 취약점에서는 고정된 경로와 파일명을 사용하므로, 파일 시스템을 기반으로 한 추가적인 공격 기법이나 기타 응용 취약점으로 악용될 가능성은 상대적으로 낮습니다

감사합니다